

Security Testing Scope Statement — Kopi Kita

Signed by: Irfan Sangjuara · **Date:** 2026-10-08

Project: Kopi Kita — coffee shop web app (Next.js app router, Express API, Postgres)

Repository: <https://github.com/Irfansangjuara/kopi-kita>

1. Assets I MAY test

- The GitHub repository I own (source review, dependency scans, secret scans, CI workflows).
- The application built and started locally on my own laptop, at `http://localhost:3000` (and `http://localhost:4000` if the API runs standalone).
- The CI pipeline inside that repository, including the containerised Postgres service used by CI jobs.
- A database branch explicitly created for testing (local Docker Postgres, or a Neon dev/ci branch), never the production branch.
- My own Vercel preview deployments, only for single manual requests with `vercel curl` (no scanning).

2. Assets I may NOT test

- The production `*.vercel.app` URL and `https://kopikita.copilotmarketing.id` with any active scan, fuzzing, or load test. Vercel permits penetration testing on Pro and Enterprise only; Kopi Kita runs on Hobby.
- The Neon **production** database (no load testing, no destructive queries, no schema experiments).
- Any application, domain, or repository that does not belong to me — classmates' apps, the Universa app, and any other third-party system, "just for fun" included.
- Anything behind someone else's account, even if I can reach it.

3. Forbidden activities

- Brute force, credential stuffing, denial of service, stress or load testing against production.
- Active scanning (DAST, fuzzing, automated vulnerability scanners) against any production URL or third-party infrastructure. Dynamic scans run only against a local build in CI (`http://localhost:3000`).
- Using real customer data (names, WhatsApp numbers, booking notes) in tests, screenshots, or reports. Dummy data only.
- Rewriting git history or rotating production secrets without the owner's approval.
- Sharing, publishing, or committing any secret, token, or personal data found during testing.

4. Legal basis

- **Criminal Code (KUHP), Law 1/2023, Article 332** — in force since 2 January 2026, replacing Articles 30 and 46 of the ITE Law: accessing another party's electronic system without authorisation is punishable by up to 6 years, up to 7 years where the purpose is to obtain data, and up to 8 years where a security system is broken. Testing my own system, within the limits above, stays inside "with authorisation".
- **Personal Data Protection Law (UU PDP), Law 27/2022** — in full force since 17 October 2024. Names and phone numbers in the bookings table are personal data; as data controller I am responsible for keeping them out of tests, logs, analytics, and reports.

I have read this statement, I understand the limits, and I will follow them.

Signature

Date